

Exercise 1: Service

In this exercise, you will disable service %Service_Terminal on Ubuntu, and see how service controls connections to IRIS.

For this exercise, you need to know the following:

- %Service_Console is only for Windows and %Service_Terminal is only for Linux/UNIX.
- To enable/disable a service, use the Management Portal: System Administration > Security > Services > Select service > Select Service enabled.
- On Ubuntu, to access your instance using %Service_Terminal, type the following:

```
$ iris session iris
```

All below operations are on **irisa** instance:

1. Access IRIS by %Service_Terminal:

```
$ iris session iris
```

After login IRIS successfully, quit IRIS session by typing **h**:

```
USER>h
```

2. Disable %Service_Console or %Service_Terminal, depending on your operating system.

Open a Terminal session. What happened?

-
3. Re-enable the service.

```
docker exec -it irisa iris session IRIS
```

Exercise 2: Authentication

In this exercise, you will test different authentication mechanisms using %Service_Terminal on Ubuntu.

For this exercise, you need to know the following:

- %Service_Console is only for Windows and %Service_Terminal is only for Linux/UNIX.

- To enable an authentication mechanism **for the instance**, use:
System Administration > Security > System Security > Authentication / Web Session Options > Select authentication mechanism.
- To enable a service, use the Management Portal:
System Administration > Security > Services > Select service > Select Service enabled.
- To change the authentication method **of a service**, use the Management Portal:
System Administration > Security > Services > Select service > Select or Clear authentication method.
- On Ubuntu, to access your instance using %Service_Terminal, type the following:
`$ iris session iris`
- To determine the name of the user you are logged in as, use:
`USER>write $USERNAME`

All below operations are on **irisa** instance:

1. Add **Operating System** as a valid authentication mechanism for this instance.
2. Test each authentication method in the chart below for the %Service_Terminal (Ubuntu) and complete the chart with the results. Make sure to clear all authentication methods for the service other than the one being tested.

If you are prompted, login using SuperUser.

Authentication Mechanism	Are you prompted for a username?	What username/password was used?
Operating System		
Password		

3. When you were not prompted for a username, how did the system determine which username to use?

4. Add Unauthenticated as valid for %Service_Console or %Service_Terminal.
5. Verify you have Login Failure and Protect system audit events enabled for auditing.
6. Try to log in as Unauthenticated by pressing ENTER for Username and Password. What is the error message in the audit log for the login attempt?

This time you passed authentication, but failed authorization. This means UnknownUser was considered valid but did not have the correct permission (authorization). Next module you will learn more about authorization.

7. Try to log into a Terminal session with an invalid password. According to the audit log entry, what authentication method failed?

8. Add Operating System as valid for %Service_Console or %Service_Terminal.
9. Bring up a Terminal session. According to the audit log entry, what authentication was used?

10. Specify Password as the only valid authentication method for %Service_Console or %Service_Terminal.

Exercise 3: Authentication – TOTP

In this exercise, you will test TOTP for IRIS System Management Portal.

For this exercise, you need to know the following:

- To enable an authentication mechanism **for the instance**, use:
System Administration > Security > System Security > Authentication / Web Session Options > Select authentication mechanism.

1. Enable Time-based One-time authentication. Check ***Allow Time-based One-time authentication***, and input issuer name, like ***MyIRIServer***

System > Security Management > Authentication/Web Session Options - (security settings)

Authentication/Web Session Options

Save Cancel

Edit Security Authentication/Web Session Options:

Allow Unauthenticated access ☒

Allow O/S authentication ☒

Allow O/S authentication with Delegated authorization ☐

Allow O/S authentication with LDAP authorization ☐

Allow Password authentication ☒

Allow Delegated authentication ☐

Always try Delegated authentication ☐

Allow Kerberos authentication ☒

Allow LDAP authentication ☐

Allow LDAP cache credentials authentication ☐

Allow OAuth2 authentication ☐

Allow creation of Login Cookies ☐ Login Cookie expire time (secs)
0 implies non-persistent cookie

Allow Two-factor Time-based One-time Password authentication ☒

Two-factor Time-based One-time Password issuer

Allow Two-factor SMS text authentication ☐

JWT Issuer field

JWT Signature Algorithm

2. Enable applications to use TOTP. Here application is the System Management Portal.

Go to SMP>System Administration>Security>Application> Web Application, click **/csp/sys**

Check ***Two-factor Time-based One-time Password***, and save the change

Edit Web Application

Save

Cancel

Edit definition for web application /csp/sys:

General
Application Roles
Matching Roles
Cross-Origin Settings
Percent Class Access

Name /csp/sys
Description System Management Portal
Namespace %SYS
Default Application for %SYS: /csp/sys
Namespace Default Application

Enable Application
Enable
REST
Dispatch Class
Required.
Redirect Empty Path
Enable Traces
Use JWT Authentication
WSGI [Experimental]
CSP/ZEN
Analytics
Inbound Web Services
Prevent login CSRF attack
Enable Traces

Security Settings
Resource Required
Group By ID %ISCMgtPortal
Allowed Authentication Methods
Unauthenticated
Password
Kerberos
Two-factor Time-based One-time Password
Permitted Classes

Session Settings
Session Timeout 28800 seconds
Event Class .cls
Use Cookie for Session Always
Session Cookie Path /csp/sys/
Session Cookie Scope Strict
User Cookie Scope Strict

CSP File Settings
Serve Files Always and cached
Serve Files Timeout 3600 seconds
Physical Path /usr/irissys/csp/sys/
Browse...
Package Name %cspapp
Default Superclass %CSP.Util.Domain
Web Settings
Recurse
Auto Compile
Lock CSP Name

Custom Pages
Login Page
Change Password Page
Custom Error Page

3. Configure users to use TOTP as 2FA

Go to SMP>System Administration>Security>Users, click on SuperUser

check **Time-based One-time Password enabled**, and check **Display Time-Based One-time Password QR Code on next login**, and save the change

Edit User

[Save](#)[Profile](#)[Cancel](#)

Edit definition for user SuperUser:

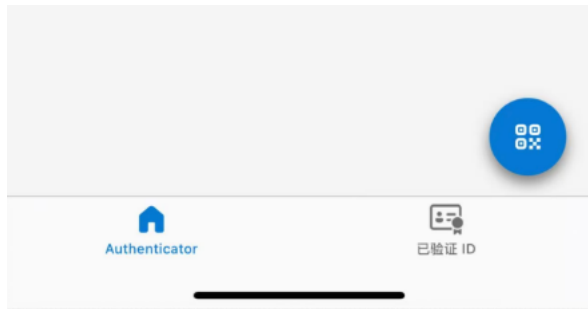
[General](#)[Roles](#)[EscalationRoles](#)[SQL Admin Privileges](#)[SQL Tables](#)[SQL Views](#)**Name**

Required.

Full Name **Comment** **Password** ☐ Enter new password ☒ Leave as is**Change password on next login** ☐**Password never expires** ☐**User enabled** ☒**Account Never Expires** ☒**Account expiration Date** (yyyy-mm-dd)**Startup Namespace** **Startup Tag^Routine** **Email Address** **Mobile Phone Service Provider** [Create a new provider](#)**Mobile Phone Number** **Two-factor Authentication****Time-based One-time Password enabled** ☒**Display Time-Based One-time Password QR Code on next login** ☒ (Not Recommended)[Generate a new Time-based One-time Password Key](#)**Issuer** MyIRIServer**Account** SuperUser**Base 32 Time-based One-time Password (OTP) Key** 4Y3A O2NM 245O S4AQ 6E2D DJF2 4BKR OOBH

4. Configure MS Authenticator app on your mobile phone

Open MS Authenticator on your mobile phone, scan above QR code to create a new account.



5. Login SMP with SuperUser, and then input Verification code showed on MS Authenticator app. It should lead you into SMP.



实例: IRIS

The system administrator has enabled Two-factor authentication for your account.

Your Two-factor authentication requires the use of an authenticator application. These applications require you to enter a Time-based One-time Password key.

If your authenticator application supports scanning a QR code (barcode) to enter the key, you can enter the key by scanning the following QR code:



Once you have scanned the QR code, enter the 6-digit verification code generated by your authenticator application.

If you cannot scan the QR code, then you must enter the following information into your authenticator manually, then enter the 6-digit verification code generated by your authenticator application.

Issuer: SIPH-IRIS

Account: SuperUser

Base 32 Time-based OTP Key: 4Y3A O2NM 245O S4AQ 6E2D DJF2 4BKR OOBH

验证码

提交

取消

Exercise 4: Authorization: Basics

In this exercise, you will create users and roles for the User namespace.

For these steps, you need to know the following points:

- To create a user, use the Management Portal:
System Administration > Security > Users > Create New User.
 - To create a role, use the Management Portal:
System Administration > Security > Roles > Create New Role.
 - To assign privileges to a role, use the Management Portal:
System Administration > Security > Roles > Select the role. Click Add. Select the resource. Click Ok and Save.
 - To assign a user to a role, use the Management Portal.
System Administration > Security > Roles > Select the role. Click the Members tab. Move the user to the Selected box, and click the Assign button.
1. Create the users and roles as described in the table below. **Notice all newly created roles are empty except for AppDeveloper.** Assign the user to the role indicated. For any fields not specified in the table, accept the default or leave empty.

Note: The User Description below describes what a role will eventually be able to do (once the next few module exercises are completed). Do not implement anything based on the description—it is for informational purposes only.

Username/password and User Description	Startup Namespace	Role Name
Chris/demo Customer data admin - Administrators of Customer data		CustAdmin
Olaf/demo Overall admin - Administrators for Phonebook application and all related data.	USER	OverallAppAdmin
Anita/demo Application developer - Developers for Phonebook application.	USER	AppDeveloper (Copy from: %Developer)
Bo/demo Backup operator - System operators. Able to perform limited functionality, such as backups, via the Management Portal		%Operator (existing role)

2. Verify Anita, the Application developer, can log into Terminal. If you are not being prompted for a username when bringing up Terminal, change the %Service_Console to only allow Password, not Operating System.

3. Verify Anita can read and write to the USER database.

To do so, create and write the global ^anita in the USER namespace.

```
USER>set ^anita = 1
USER>write ^anita.
```

4. Can Chris, the Customer admin, log into Terminal? Why or why not?

5. Try to log into the Management Portal as Anita, the application developer.

What happened?

Why does this behavior differ from logging in as SuperUser?

Exercise 5: Authorization: Application

In this exercise, you will create resource and change web application security setting.

1. Create a FHIR Server

Create a new namespace and database, named as FHIR.

Go to SMP>Health, click on **FHIR**, select **FHIR Server Management**, click **Add new server**.

Select **FHIR** in Namespace, input Name as **MyFHIRServer**, keep others as default, click **create**.

Add a FHIR Server

Namespace *

FHIR

Name *

MyFHIRServer

FHIR Version *

FHIR R4

URL *

/csp/healthshare/fhir/fhir/r4a

Custom Packages

Advanced Configuration

Cancel

Create

2. Test the application by Postman

Use Postman to test connection to FHIR Server

- GET `http://127.0.0.1:8080/csp/healthshare/fhir/fhir/r4/metadata`
- Authentication Type: Basic Authentication
- UserName: Anita
- Password: demo

what is in response?

3. Create resource

Go to SMP>System Administration>Security>Resource. Click button **Create New Resource**, input resource name as **MyFHIRSvr**, save.

4. Change the web application

Go to SMP>System Administration>Security>Application>Web Application. Select **/csp/healthshare/fhir/fhir/r4**, select **MyFHIRSvr** in dropdown list of **Resource Required**, and save.

5. Try step 2 again.

what is in response this time, and why?

6. Try again with user SuperUser.

what is in response this time, and why?

7. How many ways can you grant the application access to Anita?
